

Cybersecurity Risk Assessment Report

Organization: Ke'Anna Service Counter

Industry: Financial Services / Consumer Services

Assessment Type: Simulated Cybersecurity Risk Assessment

Assessment Focus: Information Security, Access Control, Data Protection, and Business Continuity

Date: August 2026

Executive Summary

Ke'Anna Service Counter is a fictional financial services organization that provides consumer services including loan processing, check-cashing, payment processing, and customer account services. Because the organization handles sensitive financial and personally identifiable information (PII), protecting its information systems and customer data is a critical business requirement.

This simulated cybersecurity risk assessment was conducted to identify potential threats and vulnerabilities affecting the organization's technology environment, evaluate the likelihood and potential impact of identified risks, and recommend appropriate security controls.

The assessment evaluated ten organizational assets, including employee workstations, a customer database, loan and check processing systems, a file server, Active Directory, network infrastructure, Microsoft 365/cloud storage, customer financial records, and backup systems.

A quantitative risk-rating methodology was used in which **Risk Score = Likelihood × Impact**. Likelihood and impact were each rated on a scale from 1 to 5. Risk scores were then categorized as Low, Moderate, High, or Critical.

The assessment identified **three Critical risks and seven High risks**. The highest-scoring risks involved ransomware affecting the file server and account takeover involving Microsoft 365/cloud storage, both of which received a score of 20 out of 25.

The assessment recommends prioritizing multi-factor authentication (MFA), improved backup protection, vulnerability and patch management, least-privilege access, security monitoring, data protection, and employee security awareness.

Organization Overview

Ke'Anna Service Counter is a fictional small-to-medium-sized financial services organization. The company provides services that may include:

- Loan application and processing assistance
- Check-cashing services
- Payment processing
- Customer account services
- Financial record management

The organization relies on information technology to process transactions, communicate with customers, store records, and manage employee access to business systems.

Because of the nature of its services, the organization may handle sensitive information including:

- Customer names and addresses
- Social Security numbers
- Government-issued identification information
- Bank account information
- Loan applications
- Payment information
- Check information
- Transaction history
- Employee records
- Authentication credentials

Unauthorized disclosure, modification, destruction, or loss of this information could result in financial losses, identity theft, operational disruption, reputational damage, and loss of customer trust.

Assessment Objectives

The objectives of this assessment were to:

1. Identify important organizational assets and information systems.
2. Identify potential cybersecurity threats affecting those assets.
3. Identify vulnerabilities that could allow threats to succeed.
4. Evaluate existing security controls.

5. Calculate risk using likelihood and impact.
6. Prioritize identified risks.
7. Recommend appropriate risk treatments.
8. Map recommended security practices to the NIST Cybersecurity Framework (CSF) and CIS Controls.

Assessment Scope

The assessment focused on ten representative assets within the fictional organization:

Asset ID	Asset
A-01	Employee Workstations
A-02	Customer Database
A-03	Loan Processing System
A-04	Check Processing System
A-05	File Server
A-06	Active Directory
A-07	Firewall / Router

A-08	Microsoft 365 / Cloud Storage
A-09	Customer PII & Financial Records
A-10	Backup System

The assessment is a simulated exercise and does not represent an actual security assessment of a real organization.

Risk Assessment Methodology

A qualitative-to-quantitative risk methodology was used to evaluate the identified risks.

Likelihood

Likelihood represents the estimated probability that a threat could successfully exploit an identified vulnerability.

Rating	Description
1	Rare
2	Unlikely
3	Possible
4	Likely
5	Almost Certain

Impact

Impact represents the potential severity to the organization if the risk occurs.

Rating	Description
1	Negligible
2	Minor
3	Moderate
4	Major
5	Severe

Risk Calculation

The assessment uses:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

Risk scores were categorized as follows:

Score	Risk Level
1–4	Low
5–9	Moderate
10–15	High
16–25	Critical

This scoring model was applied consistently across the ten identified risks.

Risk Register

The following risk register documents the cybersecurity risks identified during the simulated assessment. Each risk was evaluated based on likelihood and impact, with the resulting risk score used to determine the overall risk level. Recommended treatments are mapped to applicable NIST CSF categories and CIS Controls.

Risk ID	Asset	Threat/Risk	Likelihood	Impact	Score	Level	Priority
R-01	Employee Workstations	Phishing / credential theft	4	4	16	Critical	Immediate
R-02	Customer Database	Unauthorized access	3	5	15	High	Short Term
R-03	Loan Processing System	System compromise	3	5	15	High	Short Term
R-04	Check Processing System	Unauthorized transactions	3	5	15	High	Short Term
R-05	File Server	Ransomware	4	5	20	Critical	Immediate
R-06	Active Directory	Account compromise	3	5	15	High	Short Term
R-07	Firewall / Router	Network intrusion	3	4	12	High	Planned
R-08	Microsoft 365 / Cloud	Account takeover	4	5	20	Critical	Immediate
R-09	Customer PII	Data breach	3	5	15	High	Short Term
R-10	Backup System	Recovery failure	3	5	15	High	Immediate

Note: The complete 16-column risk register, including vulnerabilities, existing controls, recommended treatments, NIST CSF mappings, CIS Controls, status, and residual-risk tracking, is maintained in the accompanying Excel workbook.

Key Findings

The assessment identified 10 cybersecurity risks.

Critical Risks

Three risks received a Critical rating.

R-01 — Phishing / Employee Workstations

Risk Score: 16 — Critical

Employees may interact with malicious links or attachments, potentially resulting in malware infection or credential theft.

Recommended measures include:

- Multi-factor authentication
- Email filtering
- Phishing simulations
- Security awareness training
- Endpoint monitoring

R-05 — Ransomware / File Server

Risk Score: 20 — Critical

A ransomware attack could encrypt business files and disrupt the organization's operations. The risk is increased if backups are accessible from the production environment.

Recommended measures include:

- Offline or immutable backups
- Endpoint protection
- Timely patching
- Network segmentation
- Regular backup restoration testing

R-08 — Microsoft 365 / Cloud Storage Account Takeover

Risk Score: 20 — Critical

A compromised cloud account could provide unauthorized access to business communications, documents, and potentially sensitive customer information.

Recommended measures include:

- Multi-factor authentication
- Conditional access
- Security monitoring
- Periodic permission reviews
- Strong account-management practices

High-Risk Findings

Seven additional risks received a High rating.

These included:

- Unauthorized access to the customer database
- Compromise of the loan processing system
- Unauthorized activity involving the check processing system
- Active Directory account compromise
- Network infrastructure compromise
- Exposure of customer PII and financial records
- Backup failure or ransomware affecting recovery capability

These risks should receive management attention and be addressed according to their assigned remediation priorities.

Recommended Risk Treatment

The recommended treatments focus on reducing the likelihood or impact of identified risks.

Identity and Access Management

The organization should strengthen identity and access management by:

- Implementing MFA for employees
- Applying least-privilege principles
- Conducting periodic access reviews
- Restricting privileged accounts
- Strengthening password and authentication requirements

Data Protection

Sensitive customer information should be protected through:

- Encryption
- Access restrictions
- Data loss prevention controls
- Data-retention policies
- Audit logging
- Regular access reviews

Vulnerability Management

The organization should establish a formal vulnerability management process that includes:

- Regular vulnerability scanning
- Timely security patching
- Software inventory
- Firmware updates
- Periodic configuration reviews

Security Monitoring

Security logs should be collected and reviewed for suspicious activity involving:

- Authentication
- Administrative accounts
- Customer databases
- Financial transactions
- Cloud applications
- Network infrastructure

Backup and Recovery

Critical data should be backed up using a strategy that protects backups from ransomware and accidental deletion.

Recommended practices include:

- Offline or immutable backups
- Backup encryption
- Restricted backup access
- Regular restoration testing
- Documented recovery procedures

Framework Alignment

The assessment uses the **NIST Cybersecurity Framework** and **CIS Controls** to provide structure for recommended security improvements.

The NIST CSF categories represented in the assessment include:

- Protect
- Detect
- Recover

The assessment also maps identified risks to relevant CIS Controls, including:

- CIS Control 3 — Data Protection
- CIS Control 4 — Secure Configuration of Enterprise Assets and Software
- CIS Control 5 — Account Management
- CIS Control 6 — Access Control Management
- CIS Control 7 — Continuous Vulnerability Management
- CIS Control 8 — Audit Log Management
- CIS Control 9 — Email and Web Browser Protections
- CIS Control 11 — Data Recovery
- CIS Control 12 — Network Infrastructure Management
- CIS Control 14 — Security Awareness and Skills Training

These mappings provide a structured basis for implementing and prioritizing security improvements.

Risk Prioritization

Based on the calculated risk scores, remediation should be prioritized as follows:

Immediate Priority

1. R-05 — File Server / Ransomware
2. R-08 — Microsoft 365 / Cloud Account Takeover
3. R-01 — Employee Workstations / Phishing

Short-Term Priority

4. R-02 — Customer Database
5. R-03 — Loan Processing System
6. R-04 — Check Processing System
7. R-06 — Active Directory

8. R-09 — Customer PII & Financial Records

Planned Priority

9. R-07 — Firewall / Router

10. R-10 — Backup System

Although R-10 is classified as a High risk and assigned an Immediate priority, backup security should be addressed alongside the ransomware risk because reliable backups are an important component of recovery from a ransomware event.

Risk Treatment Strategy

The organization should primarily use risk mitigation for the identified risks.

Risk mitigation involves implementing controls that reduce the likelihood or potential impact of a cybersecurity event.

Examples include:

Phishing → MFA + email filtering + awareness training

Ransomware → patching + endpoint protection + immutable backups

Account takeover → MFA + access reviews + conditional access

Data breach → encryption + least privilege + logging

Network intrusion → secure configuration + firmware updates + monitoring

The effectiveness of these controls should be reassessed after implementation.

Residual Risk

Residual risk represents the level of risk remaining after recommended controls have been implemented.

Residual risk has **not yet been assessed** in this simulated assessment because the recommended controls have not been implemented or tested.

A future assessment should reevaluate:

- Likelihood
- Impact
- Control effectiveness
- Remaining vulnerabilities
- Remaining exposure

The risk register can then be updated to document the organization's residual risk.

Conclusion

The simulated assessment demonstrates that Ke'Anna Service Counter's greatest cybersecurity concerns involve phishing, ransomware, unauthorized access, account compromise, and protection of sensitive customer information.

The assessment identified three Critical risks and seven High risks. The most significant risks involve the organization's file server and cloud environment, where successful attacks could result in significant operational disruption or unauthorized access to sensitive information.

Implementing MFA, stronger access controls, vulnerability management, security monitoring, employee security awareness, data protection measures, and resilient backups would significantly improve the organization's security posture.

The accompanying risk register provides a structured method for tracking these risks, assigning remediation priorities, and monitoring their status over time.

Assessment Status: Simulated / Portfolio Project

Residual Risk: Not Yet Assessed